

SSH Brute Force Attack Detection Example

Simple passwords used on the server with an SSH brute force attack can be easily found by the attackers. If such attacks fail, the attacker will only attempt a certain number of failed passwords. If successful, the password is entered successfully after a certain number of unsuccessful login attempts.

In an example SSH brute force analysis, when we view a linux machine log with the contents of the “/var/log/auth.log.1” file and failed login attempts, we can see who the failed login attempts belong to.

```
cat auth.log.1 | grep "Failed password" | cut -d " " -f10 | sort | uniq -c | sort
```

```
root@ip-172-31-18-193:/var/log# cat auth.log.1 | grep "Failed password" | cut -d " " -f10 | sort | uniq -c | sort
  1 times:
  2 from
 13 invalid
 13 root
 14 analyst
 614 letsdefend
root@ip-172-31-18-193:/var/log#
```

A command such as the one below can be used to locate the IP addresses that made these attempts.

```
cat auth.log.1 | grep "Failed password" | cut -d " " -f12 | sort | uniq -c | sort
```

```
root@ip-172-31-18-193:/var/log# cat auth.log.1 | grep "Failed password" | cut -d " " -f12 | sort | uniq -c | sort
  1 Failed
  2 port
 13 admin
 30 188.58.65.203
 96 173.249.51.74
232 46.31.148.75
283 176.40.39.151
root@ip-172-31-18-193:/var/log#
```

Users who successfully log in can also be detected with the following command.

```
cat auth.log.1 | grep "Accepted password"
```

```
root@ip-172-31-18-193:/var/log# cat auth.log.1 | grep "Accepted password"
Jul 14 08:48:35 ip-172-31-1-195 sshd[1166]: Accepted password for analyst from 172.31.1.195 port 52516 ssh2
Sep  4 19:15:49 ip-172-31-12-170 sshd[1899]: Accepted password for analyst from 172.31.12.170 port 39284 ssh2
Sep  4 19:17:13 ip-172-31-12-170 sshd[2055]: Accepted password for analyst from 172.31.12.170 port 39288 ssh2
Sep  4 19:18:43 ip-172-31-12-170 sshd[2191]: Accepted password for analyst from 172.31.12.170 port 39298 ssh2
Sep  4 19:18:48 ip-172-31-12-170 sshd[2302]: Accepted password for analyst from 172.31.12.170 port 39300 ssh2
Sep  4 19:22:14 ip-172-31-12-170 sshd[2419]: Accepted password for analyst from 172.31.12.170 port 39302 ssh2
Sep  4 19:34:45 ip-172-31-12-170 sshd[2633]: Accepted password for analyst from 172.31.12.170 port 39312 ssh2
Sep  4 19:39:43 ip-172-31-12-170 sshd[2908]: Accepted password for analyst from 172.31.12.170 port 39326 ssh2
Sep  4 19:39:46 ip-172-31-12-170 sshd[3012]: Accepted password for analyst from 172.31.12.170 port 39328 ssh2
Sep  4 20:11:04 ip-172-31-12-170 sshd[3425]: Accepted password for letsdefend from 188.58.65.203 port 52313 ssh2
Sep  4 20:11:57 ip-172-31-12-170 sshd[3550]: Accepted password for letsdefend from 188.58.65.203 port 51855 ssh2
root@ip-172-31-18-193:/var/log#
```

As can be seen here, successful login attempts are seen with two different users from two different IP addresses.

When the previous failed login attempts are compared, it is seen that the "analyst" user did not have an unsuccessful login attempt before from the ip address he successfully logged in. However, it is clearly seen that many unsuccessful attempts were made with the "letsdefend" user at the IP address of 188.58.65.203. This shows us that the attacker successfully logged in with the letsdefend user during the brute force.

```
Sep 4 20:11:03 ip-172-31-12-170 sshd[3416]: Failed password for letsdefend from 188.58.65.203 port 52067 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3421]: Failed password for letsdefend from 188.58.65.203 port 52040 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3420]: Failed password for letsdefend from 188.58.65.203 port 51653 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3425]: Failed password for letsdefend from 188.58.65.203 port 52313 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3426]: Failed password for letsdefend from 188.58.65.203 port 51977 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3423]: Failed password for letsdefend from 188.58.65.203 port 51927 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3418]: Failed password for letsdefend from 188.58.65.203 port 51960 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3428]: Failed password for letsdefend from 188.58.65.203 port 52092 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3424]: Failed password for letsdefend from 188.58.65.203 port 51645 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3427]: Failed password for letsdefend from 188.58.65.203 port 52204 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3431]: Failed password for letsdefend from 188.58.65.203 port 52642 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3422]: Failed password for letsdefend from 188.58.65.203 port 52560 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3430]: Failed password for letsdefend from 188.58.65.203 port 52373 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3429]: Failed password for letsdefend from 188.58.65.203 port 52523 ssh2
Sep 4 20:11:03 ip-172-31-12-170 sshd[3417]: Failed password for letsdefend from 188.58.65.203 port 51994 ssh2
Sep 4 20:11:04 ip-172-31-12-170 sshd[3446]: Failed password for letsdefend from 188.58.65.203 port 52598 ssh2
Sep 4 20:11:04 ip-172-31-12-170 sshd[3425]: Accepted password for letsdefend from 188.58.65.203 port 52313 ssh2
Sep 4 20:11:04 ip-172-31-12-170 pam_unix(sshd:session): session opened for user letsdefend by (uid=0)
Sep 4 20:11:04 ip-172-31-12-170 systemd-logind[464]: New session 14 of user letsdefend.
```

As seen above, successful and unsuccessful logged in users can be easily found with basic Linux commands. When these two results are examined in detail, it is seen that there is a successful entry after many unsuccessful attempts by the letsdefend user from the 188.58.65.203 IP address.

HTTP Login Brute Force Attack Detection Example

In HTTP login brute force attacks, the attacker usually tries a password with a dictionary attack on a login page. In order to analyze this, the content of the relevant log file should be opened with a text editor and the logs should be examined.

The following screenshot shows an HTTP login brute force attack. It is seen that the user found the password by successfully entering the password after a certain number of unsuccessful login attempts. Here, the difference between the package sizes in the response returned to failed login attempts and the package sizes in the response returned to successful login attempts is clearly seen.

